PAI 4. DevSecOps - ASEGURAMIENTO DE LA CADENA DE SUMINISTRO EN EL DESARROLLO DE APLICACIONES WEB

Grupo de Investigación **IDEA Research Group**,
Universidad de Sevilla

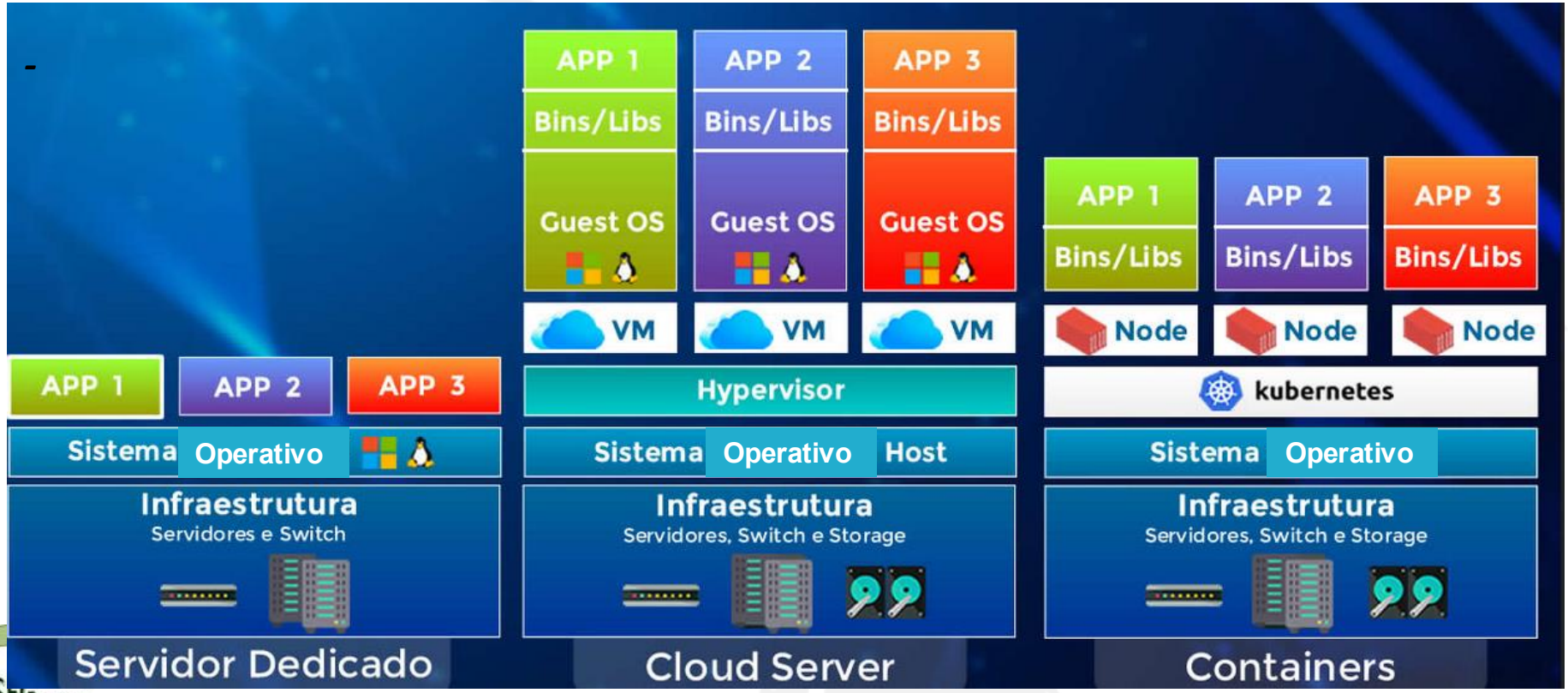
Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model

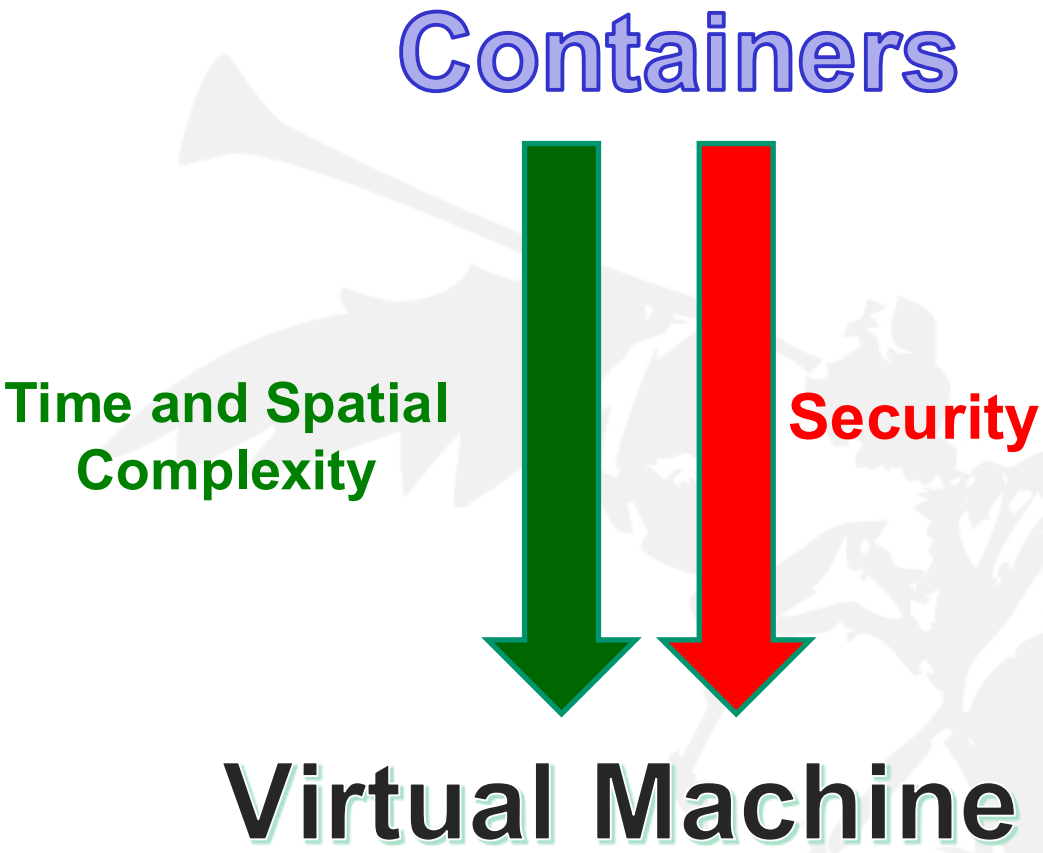
Software Fail Watch

Año 2017	Cifras
Población mundial en 2017:	7.400.000.000 (aproximadamente)
Número de personas afectadas por fallos software:	3.683.212.665 (por lo menos)
Porcentaje de personas afectadas en 2017:	50% (aproximadamente)
Pérdidas económicas debidas a fallos software:	1.715.430.778.504,00 U$S
Tiempo acumulado (perdido):	46 minutos 8 horas 3 días 2 semanas 8 meses 268 años
Datos de "Software Fail Watch: 5th Edition" Copyright ©2019 Tricentis:	https://www.tricentis.com/resources/software-fail-watch-5th-edition/

Gustavo Márquez Sosa © / 2021 / Todos los derechos reservados

Además, los productos software se está pasando desde un escenario de aplicaciones software monolíticas a aplicaciones basadas en microservicios:

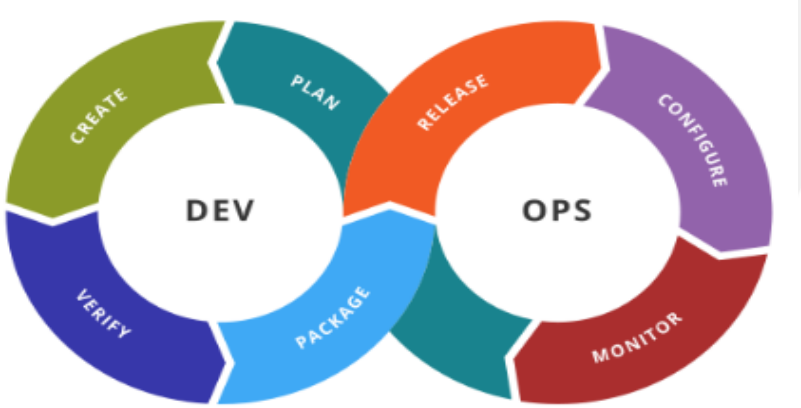



Containers
Time and Spatial Complexity
Security
Virtual Machine

- Actualmente la empresa sigue para sus desarrollos un Pipeline de para integración y despliegue continuo (CI/CD) gracias a la automatización

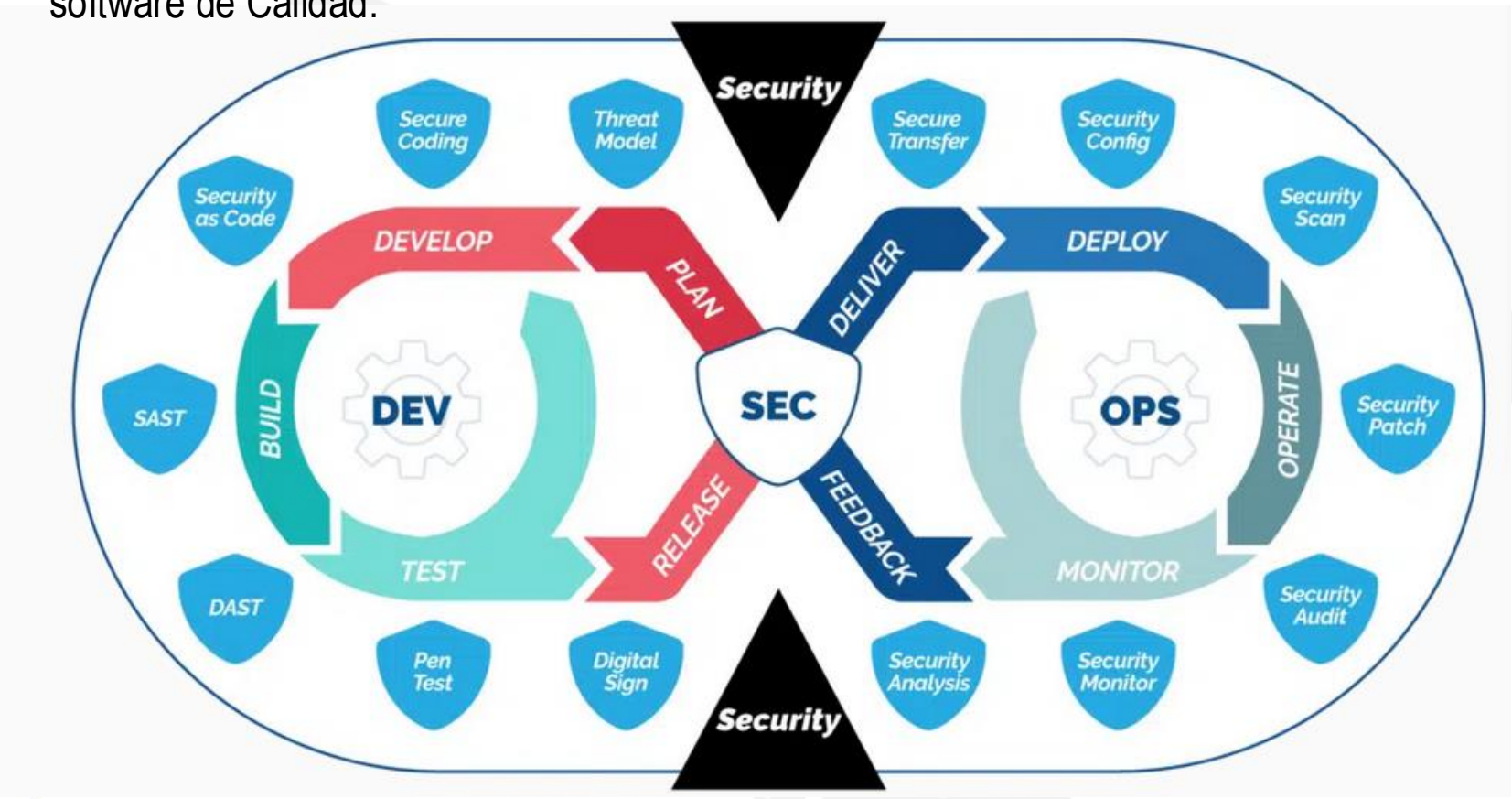
- Objetivo: **Mitigar o eliminar el riesgo de generar código con vulnerabilidades de seguridad**, utilizando diferentes herramientas de automatización.

- **Los containers ofrecen beneficios claves que ayudan a facilitar DevOps y lo hacen mucho más simple.**
  - **DevOps**: Buenas prácticas que automatizan los procesos entre los equipos de Desarrollo y Operación para build, testear, y liberar productos software rápidamente y de calidad.



Y la security y reliability??

DevSecOps nos lleva a pensar desde el principio del DevOps en la seguridad de la aplicación y las infraestructuras. Se **deben seleccionar las herramientas que continuamente integra la security y reliability** para desarrollar y operar con productos software de Calidad.



Las herramientas que consideran se podrían ser:

- **Static Application Security Testing (SAST)**
- **Dynamic Application Security Testing (DAST)**
- **Interactive Application Security Testing (IAST)**
- **Software Composition Analysis (SCA)**
- **Security in Infrastructure as Code (IaC)**

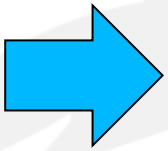
Estas herramientas se podrían integrar para su gestión en un único sistema, como podría ser **DefectDojo**, para facilitar toda la gestión de las vulnerabilidades y encontrar los bugs de seguridad en etapas más tempranas

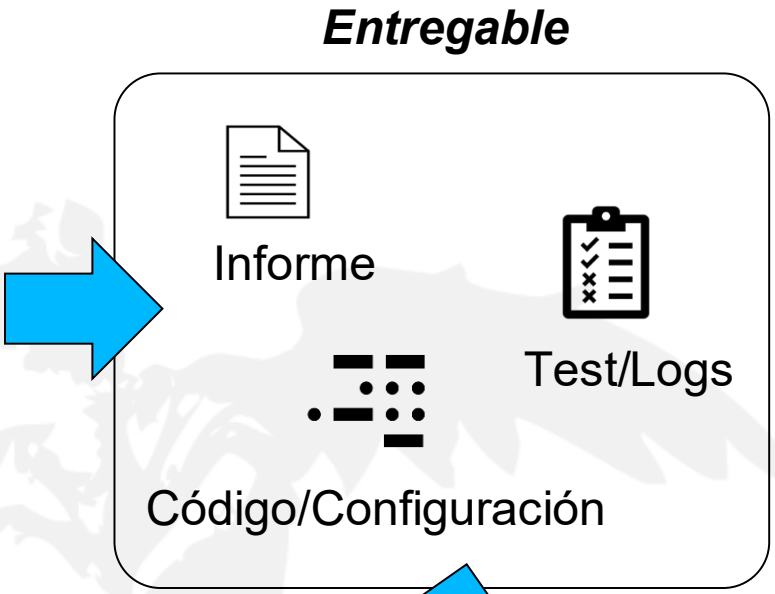
Pipeline DevSecOps debe cumplir los siguientes **objetivos**:

1. Definir una **Pipeline CI/CD** en un proyecto de prueba en un repositorio de código (SCM)
2. Seleccionar al menos **tres** herramientas de Testeo de Seguridad (**SCA, SAST, IAST, DAST, Security IaC**) para incluirlas en el Pipeline para dotarlos de capacidades DevSecOps
3. Integrar las herramientas de testeo en el ciclo de vida del desarrollo para hacer **pipeline DevSecOps**
4. Desarrollar los **tests** correspondientes que permitan detectar vulnerabilidades en cada etapa del Pipeline DevSecOp.
5. Seleccionar una **herramienta de gestión de vulnerabilidades para integrar, priorizar y clasificar las vulnerabilidades de Seguridad** que se vayan encontrando por las herramientas de testeo en el Pipeline DevSecOps. Como recomendación podría usarse **DefectDojo** o cualquier otra herramienta que se considere oportuna.

¿Cómo y qué entrego en el PAI?

Especificación





Deadline: 27 de abril (23:59)

Penalizaciones: 10%

Muchas gracias por vuestra colaboración